Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.5 / COMPANION WORKBOOK

Harden with Group Policy

OU design, Group Policy processing & DISA GPOs proven by rescan

Build the organizational units the hardening hangs on, learn exactly how Group Policy decides what applies, import the DISA STIG Group Policy objects course 1.4 staged and link them to SBD-DC01 and SBD-DC02 by OU, and prove the change with a rescan matched to course 1.4's baseline, updated checklists and an owned exception record.

MATERIALS EDITION 2.0 / COURSE 1.5

Updated 14 October 2026 · sbd-harden-baseline

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design and build the OU structure

02 Learn how Group Policy applies

03 Import and link the DISA GPOs

04 Rescan, reconcile, and record

05 Set the rescan cadence and exception record

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

This course builds the organizational unit (OU) structure, learns how Group Policy decides what applies, imports the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) Group Policy objects (GPOs) that course 1.4 staged, and proves the result with a rescan against course 1.4's baseline. Names, paths and versions below are examples — adapt them, but rescan with exactly the SCC version, benchmark release and profile in handoff.txt. Expect STIG settings to change behavior: that is the point, and the reason everything is scanned and recorded.

Prerequisites

- ☐ Complete courses 1.1–1.4: both domain controllers healthy and replicating, DNS (course 1.2) and the domain time design (course 1.3) in place, and course 1.4's sealed baseline — the DISA GPO package hashed in C:\Staging\DISA, the raw results, three checklists and findings record under C:\Evidence\baseline, and handoff.txt with the versions to reuse.
- ☐ Work at each domain controller's VM console with an authorized Domain Admin account: until course 1.8 builds AdminJumpBox01, that is where administration happens, with SCC on both controllers and STIG Viewer on SBD-DC01.
- ☐ Leave SCC, STIG Viewer and the benchmark at the versions course 1.4 recorded until this course's rescan is filed.

What this course builds

- Design OUs for delegation and policy targeting, and redirect the default containers.
- Predict which GPO wins from processing order, link order, inheritance, filtering and loopback, and confirm it with gpresult.
- Import the DISA GPO package through the central store and link it by OU, with account policies at the domain root.
- Prove the hardening with a rescan matched to course 1.4's baseline, updated checklists and an owned exception record.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DC01 — name, address, OS build	
SBD-DC02 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Design and build the OU structure

WHY THIS MATTERS Organizational units exist for delegation and Group Policy targeting, not to mirror an org chart. Build the structure the hardening policies will hang on before importing any of them.

In this lesson you will

- Design an OU structure around delegation and Group Policy targeting.
- Create protected OUs and redirect the default Computers and Users containers.
- Explain why the built-in Domain Controllers OU stays untouched.

Follow the build

1. Design the structure by administration: a top-level SBD OU containing Servers, Workstations, Users, Groups, and an Admin OU for privileged accounts. The built-in Domain Controllers OU stays where it is and keeps its name.
2. Create the planned OUs with accidental-deletion protection enabled. Record each OU's purpose and who will administer its contents; an OU with no delegation or policy purpose is clutter.
3. Redirect the default containers with redircmp and redirusr: new computer accounts to the Workstations OU and new user accounts to the Users OU. Group Policy cannot be linked to the default containers, so anything landing there would get only domain-level policy, never the OU-linked hardening. Join servers straight into the Servers OU with Add-Computer -OUPath, so they never pass through the workstation policies.
4. Keep privileged accounts and systems separate: the Admin OU holds the identities that administer the domain controllers. The domain-joined PKI servers from course 1.6 and SBD-DHCP01 from course 1.7 join the Servers OU, and course 1.8 adds a Tier 0 Servers OU and the admin seats' sub-OUs. Do not nest deeper than the delegation plan requires.

Check your result

```
New-ADOrganizationalUnit -Name SBD -Path 'DC=sbd,DC=test' -ProtectedFromAccidentalDeletion
$true
'Servers', 'Workstations', 'Users', 'Groups', 'Admin' | ForEach-Object { New-
ADOrganizationalUnit -Name $_ -Path 'OU=SBD,DC=sbd,DC=test' -
ProtectedFromAccidentalDeletion $true }
redircmp 'OU=Workstations,OU=SBD,DC=sbd,DC=test'
redirusr 'OU=Users,OU=SBD,DC=sbd,DC=test'
New-Item -ItemType Directory C:\Evidence\hardened -Force | Out-Null
Get-ADOrganizationalUnit -Filter * -Properties ProtectedFromAccidentalDeletion | Select-
Object Name, DistinguishedName, ProtectedFromAccidentalDeletion | Export-Csv C:\Evidence\
hardened\ou-design.csv -NoTypeInformation
Get-ADDomain | Select-Object ComputersContainer, UsersContainer
Get-ADDomainController -Filter * | Select-Object Name, ComputerObjectDN
```

WHAT SUCCESS LOOKS LIKE The planned OUs exist with deletion protection, the computer and user redirects point at the Workstations and Users OUs, both controllers are still in the Domain Controllers OU, and each OU has a recorded purpose and administrator.

© 2026 Secure By Design Team LLC.

Your record

Evidence to keep: Keep the OU design sheet: each OU's distinguished name, purpose and delegated administrator, the ou-design.csv export in C:\Evidence\hardened, and the redirect commands with their output.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What should drive the shape of the OU structure?

REMEMBER OUs follow administration, not the org chart. The default containers are redirected so nothing joins unmanaged. The Domain Controllers OU remains the link point for DC policies.

Microsoft · New-ADOrganizationalUnit

Microsoft · Redirect the Users and Computers containers

LESSON 02 / ABOUT 30 MIN

Learn how Group Policy applies

WHY THIS MATTERS Before the DISA settings arrive, learn how a computer decides which Group Policy objects (GPOs) apply and which setting wins. Map the order, build the central store the import will use, and record what both controllers apply today.

In this lesson you will

- Predict which GPO wins from processing order, link order, inheritance, Enforced and Block Inheritance.
- Explain how security filtering, WMI filters and loopback processing change a GPO's reach.
- Build the central store and record each controller's starting policy with gpresult.

Follow the build

1. Know where a GPO lives. Its settings sit in two halves — a container object in Active Directory and a template folder in SYSVOL — and they replicate separately, by directory replication and by DFS Replication. A change made on SBD-DC01 therefore reaches SBD-DC02 in two steps: before you judge a result there, check that the GPO's AD and SYSVOL version numbers agree.
2. Learn the order. Policy applies local first, then site, domain and OU, parent OU before child, so the GPO linked closest to the computer is applied last and wins a conflict; at one OU, link order 1 is processed last and wins. Different settings add up across GPOs, but a single setting's values generally don't merge: the highest-precedence GPO that configures it wins, so a user-rights list in one GPO replaces another's instead of adding to it.
3. Treat the two overrides as exceptions. Block Inheritance on an OU stops GPOs linked above it; Enforced on a link makes that GPO win over everything below it and pierces Block Inheritance. Enforced is not a shortcut — it hides a precedence problem instead of solving it — so this network uses neither unless the exception record says why.
4. Read what narrows a GPO's reach. Security filtering applies it only to accounts with both Read and Apply group policy (Authenticated Users by default), and computers still need Read on GPOs that apply only to users, because user policy is read in the computer's security context; a WMI filter applies it only where its query is true. Loopback processing gives anyone who signs in to a computer the user settings from that computer's GPOs — merge adds them after the user's own, replace uses only the computer's — so use it only where the computer should decide; lesson 3 meets the one place this course needs it.
5. Know when policy arrives, and build the central store. Members refresh in the background every 90 minutes with a random offset of up to 30, controllers every five minutes, and gpupdate /force reapplies everything at once, though some extensions run only at startup or sign-in. On SBD-DC01, copy C:\Windows\PolicyDefinitions with its en-US folder to \\sbd.test\SYSVOL\sbd.test\Policies\PolicyDefinitions: from then on, every Group Policy editor in the domain uses these templates instead of its local ones.
6. Record the starting state before anything is imported. On both controllers, save a gpresult report of the Resultant Set of Policy (RSoP), what actually applied: the Default Domain Policy and the Default Domain Controllers Policy should be the only domain GPOs listed. Read the applied and filtered-out lists — the reasons gpresult gives, such as a security denial or a false WMI filter, are how you will troubleshoot the import.

© 2026 Secure By Design Team LLC.

Check your result

```
# Once, on SBD-DC01: create the central store from the controller's own templates
Copy-Item C:\Windows\PolicyDefinitions -Destination \\sbd.test\SYSVOL\sbd.test\Policies\
PolicyDefinitions -Recurse
# On SBD-DC01: links in precedence order, and each GPO's AD and SYSVOL versions
Get-GPInheritance -Target 'DC=sbd,DC=test'
Get-GPInheritance -Target 'OU=Domain Controllers,DC=sbd,DC=test'
foreach ($dc in 'SBD-DC01', 'SBD-DC02') { Get-GPO -All -Server $dc | Select-Object
@{n='DC';e={$dc}}, DisplayName, GpoStatus, @{n='AD';e={$_.Computer.DSVersion}},
@{n='SYSVOL';e={$_.Computer.SysvolVersion}} }
# On each controller's console; carry SBD-DC02's report to the same folder on SBD-DC01
New-Item -ItemType Directory C:\Evidence\hardened\policy-before -Force | Out-Null
gpresult /r /scope:computer
gpresult /h "C:\Evidence\hardened\policy-before\$env:COMPUTERNAME-gpresult.html" /f
```

> **WHAT SUCCESS LOOKS LIKE** You can list both controllers' GPOs in precedence order and say why each applies, nothing is Enforced or blocked, every GPO's AD and SYSVOL versions agree, the central store holds SBD-DC01's templates, and each controller's starting gpresult report is saved.

Your record

Evidence to keep: Keep both starting gpresult reports in C:\Evidence\hardened\policy-before, the inheritance output for the domain and the Domain Controllers OU, the GPO version listing, and a note of the central store's source and date.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

A GPO linked at the domain and a GPO linked to the Domain Controllers OU configure the same administrative template setting differently, and neither link is Enforced. Which value does a controller end up with?

> **REMEMBER** The closest link applies last and wins; at one OU, link order 1 wins. Enforced and Block Inheritance are exceptions to record, not tools to reach for. gpresult shows what actually applied, and why the rest was filtered out.

Microsoft · Group Policy processing

Microsoft · Group Policy scope

Microsoft · Get-GPInheritance

Microsoft · User Group Policy needs Read permission for computers

Microsoft · Create and manage the Group Policy Central Store

Microsoft · Gpupdate

Microsoft · Gpresult

Microsoft · Group Policy Modeling and Group Policy Results

LESSON 03 / ABOUT 40 MIN

Import and link the DISA GPOs

> **WHY THIS MATTERS** Group Policy is how the STIG becomes configuration. Import the package course 1.4 staged, link each policy where its systems live so the findings marked fix by GPO can close, and keep the lab's deliberate deviations written down rather than silently skipped.

In this lesson you will

- Verify the staged package and add its templates to the central store.
- Import DISA's policies and link them by OU, with account policies at the domain root.
- Handle lab-specific deviations with documentation instead of silent edits.

Follow the build

1. Start from course 1.4's handoff. Read the package release in C:\Evidence\baseline\findings\handoff.txt, confirm the package in C:\Staging\DISA still matches its connected-side hash, and only then extract it. Copy its ADMX files and their en-US ADML files into the central store from lesson 2, without replacing a newer Microsoft template with an older copy of the same file.
2. Import each policy this network uses into a new GPO with the GPMC Import Settings wizard or Import-GPO: the Windows Server domain controller, member server and user policies, and the Windows client policies for your fleet's release, which stay unlinked until courses 1.8 and 1.13 link them. Keep DISA's names behind an SBD prefix so the source release stays identifiable. An import replaces every setting in the target GPO and brings no links, security filtering or WMI filter. Where the package's user-rights settings name placeholder groups such as ADD YOUR DOMAIN ADMINS, map them to sbd.test's real groups with a migration table — check the package's support files for one before building your own in GPMC's Migration Table Editor.
3. Link by OU. Link the domain controller policy to the Domain Controllers OU at link order 1, above the Default Domain Controllers Policy, and the member-server policy to the Servers OU, so the systems later courses build there are hardened from first boot. Domain controllers read password, lockout and Kerberos policy only from GPOs linked at the domain root: if the package carries account policies, set those values in a GPO linked there above the Default Domain Policy, because at an OU they do nothing for domain accounts. Use neither Enforced nor Block Inheritance.
4. Apply the user policy where people sign in. Its settings belong to every session on a hardened server, whoever signs in — an administrator from the Admin OU, or the built-in Administrator in the default Users container, where no GPO can link. So link the DISA user policy to the Domain Controllers and Servers OUs and, in a small GPO linked to both, enable Configure user Group Policy loopback processing mode set to Merge. Record that decision — it is the only loopback this course uses — and compare it with the package's own instructions for its user policy.
5. Walk the settings that need a decision in this network — anything that assumes infrastructure the lab does not have or conflicts with an earlier design — and record each deviation with its rationale instead of deleting the setting. Check each fix-by-GPO item in course 1.4's findings record against the imported settings, so you know which ones the rescan should show closed. Then, once SBD-DC02 shows the same GPO versions, refresh policy on both controllers and confirm with gpresult that the SBD DISA GPOs apply and that replication still succeeds both ways. Finally, confirm the course 1.3 time design is intact with no time setting from Group Policy: w32tm /query /configuration must show no (Policy) value,

and any Windows Time Service setting an imported GPO carries goes back to Not Configured, with the change recorded.

Check your result

```
# On SBD-DC01. True means the package matches the hash recorded on the connected side.
$package = Get-ChildItem C:\Staging\DISA -Filter '*GPO*.zip' | Select-Object -First 1
(Get-FileHash $package.FullName -Algorithm SHA256).Hash -in (Import-Csv C:\Evidence\
baseline\transfer\connected-side-hashes.csv).Hash
Expand-Archive $package.FullName -DestinationPath C:\Staging\GPO
# Per policy; take the exact names and folders from the package:
Import-GPO -BackupGpoName '<DISA GPO name>' -TargetName 'SBD <DISA GPO name>' -Path
'<package GPOs folder>' -MigrationTable '<migration table>' -CreateIfNeeded
New-GPLink -Name 'SBD <DISA domain controller GPO name>' -Target 'OU=Domain
Controllers,DC=sbd,DC=test' -Order 1
Get-GPInheritance -Target 'OU=Domain Controllers,DC=sbd,DC=test'
# On each controller's console; carry SBD-DC02's report to SBD-DC01:
gpupdate /force
gpresult /r /scope:computer
New-Item -ItemType Directory C:\Evidence\hardened\import -Force | Out-Null
gpresult /h "C:\Evidence\hardened\import\$env:COMPUTERNAME-gpresult.html" /f
w32tm /query /source   # SBD-DC01: Local CMOS Clock; SBD-DC02: a domain controller
w32tm /query /configuration | Select-String '\(Policy\)'   # expected: no output, so no
time setting comes from Group Policy
repadmin /replsummary
```

> **WHAT SUCCESS LOOKS LIKE** The package matched its connected-side hash, the central store serves its templates, placeholder groups map to real ones, the links follow the OU design with the domain controller policy at link order 1 and nothing Enforced or blocked, gpresult on both controllers lists the SBD DISA GPOs as applied, time and replication are unchanged with no time setting from Group Policy, and every deviation has a written reason and owner.

Your record

Evidence to keep: Keep the import record — package release and hash check, each GPO's name and source, the migration table, the links with their order, the loopback decision, and both gpresult reports in C:\Evidence\hardened\import — and the deviation list with rationale and owner.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the OU work from lesson 1 matter here?

> **REMEMBER** The central store keeps policy definitions consistent across controllers. Links follow the OU design; account policies live at the domain root. Deviations are documented decisions, not deletions.

Microsoft · Group Policy processing

Microsoft · Create and manage the Group Policy Central Store

Microsoft · Gpresult

Microsoft · Import-GPO

Microsoft · Back up, restore, migrate, and copy Group Policy Objects

Microsoft · New-GPLink

Microsoft · Group Policy application rules for domain controllers

DISA · STIG Group Policy Objects package

LESSON 04 / ABOUT 35 MIN

Rescan, reconcile, and record

> **WHY THIS MATTERS** The second scan is the verdict. Rescan with exactly the versions course 1.4 used, compare each controller with its own baseline, update copies of the course 1.4 checklists, and give every remaining open item an answer.

In this lesson you will

- Rescan with course 1.4's SCC version, benchmark release and profile, and compare against the baseline.
- Update copies of the course 1.4 checklists and re-answer what the policies changed.
- Close or classify every item in the findings record.

Follow the build

1. Check that the baseline is untouched: the hash of C:\Evidence\baseline-manifest.csv must match the one course 1.4 recorded, and every file in C:\Evidence\baseline must still match the manifest. Read handoff.txt, confirm SCC and the benchmark on each controller are still those versions, and rescan both controllers locally with the same profile. Changing anything between scans makes the comparison meaningless.
2. Copy each new session into C:\Evidence\hardened\<host name> and hash it, and carry SBD-DC02's set to SBD-DC01 as in course 1.4. Compare each controller with its own baseline: which rules moved from open to pass, which stayed open, and whether any regressed. Attribute each change to the GPO that caused it — the gpresult report names the winning GPO for every setting.
3. Copy the three checklists from C:\Evidence\baseline\checklists into C:\Evidence\hardened\checklists and open only the copies in STIG Viewer, so nothing it saves can touch the baseline. Import each controller's new XCCDF results into its copy — with the benchmark and the checklist's STIG release unchanged, the import summary should match course 1.4's — then revisit every manual answer the policies may have changed, sbd.test's included, updating Finding Details and Comments with what you observed and when. Save and hash the copies; the baseline checklists stay exactly as hashed.
4. Work through the findings record. Every fix-by-GPO item should now be closed; if one isn't, find out why — the GPO didn't apply, a closer GPO won, or the setting needs the domain root or a restart. Work in a copy, C:\Evidence\hardened\findings\findings-record.csv: give each item a Resolution — closed by GPO, deviation (for lesson 5's exception record) or POA&M candidate (Plan of Action and Milestones), with its owner and date — and the Evidence that shows it. Treat any new open item as a finding to fix or classify.

Check your result

```
# On SBD-DC01: the manifest's hash must match course 1.4's record; no Compare-Object
output means no baseline file changed
Get-FileHash -Algorithm SHA256 C:\Evidence\baseline-manifest.csv
Compare-Object (Import-Csv C:\Evidence\baseline-manifest.csv).Hash (Get-ChildItem C:\
Evidence\baseline -Recurse -File | Get-FileHash -Algorithm SHA256).Hash
Get-Content C:\Evidence\baseline\findings\handoff.txt   # the SCC version, benchmark
release and profile to reuse
# On each controller, after its SCC rescan (adapt the path to SCC's results directory);
SBD-DC02 then copies its set to SBD-DC01
```

```
$session = Get-ChildItem "$env:USERPROFILE\SCC\Sessions" -Directory | Sort-Object Name |
Select-Object -Last 1
Copy-Item $session.FullName -Destination "C:\Evidence\hardened\$env:COMPUTERNAME" -Recurse
Get-ChildItem "C:\Evidence\hardened\$env:COMPUTERNAME" -Recurse -File | Get-FileHash -
Algorithm SHA256 | Export-Csv "C:\Evidence\hardened\$env:COMPUTERNAME-hashes.csv" -
NoTypeInformation
Copy-Item C:\Evidence\hardened\SBD-DC02, C:\Evidence\hardened\SBD-DC02-hashes.csv -
Destination '\\SBD-DC01\C$\Evidence\hardened\' -Recurse   # on SBD-DC02
# On SBD-DC01: verify the copy, then list each changed rule twice, <= its baseline result
and => its result now
Compare-Object (Import-Csv C:\Evidence\hardened\SBD-DC02-hashes.csv).Hash (Get-ChildItem
C:\Evidence\hardened\SBD-DC02 -Recurse -File | Get-FileHash -Algorithm SHA256).Hash
function Read-Xccdf($dir) { Get-ChildItem $dir -Recurse -Filter '*XCCDF-Results*.xml' |
Select-Xml -XPath "//*[local-name()='rule-result']" | ForEach-Object
{ [pscustomobject]@{ Rule = $_.Node.idref; Result = $_.Node.result } } }
foreach ($h in 'SBD-DC01', 'SBD-DC02') { Compare-Object (Read-Xccdf "C:\Evidence\baseline\
$h") (Read-Xccdf "C:\Evidence\hardened\$h") -Property Rule, Result | Sort-Object Rule |
Export-Csv "C:\Evidence\hardened\$h-changes.csv" -NoTypeInformation }
New-Item -ItemType Directory C:\Evidence\hardened\checklists, C:\Evidence\hardened\
findings -Force | Out-Null
Copy-Item C:\Evidence\baseline\checklists\*.cklb C:\Evidence\hardened\checklists
Import-Csv C:\Evidence\baseline\findings\findings-record.csv | Select-Object *,
Resolution, Evidence | Export-Csv C:\Evidence\hardened\findings\findings-record.csv -
NoTypeInformation
Get-ChildItem C:\Evidence\hardened\checklists -Filter *.cklb | Get-FileHash -Algorithm
SHA256 | Export-Csv C:\Evidence\hardened\checklists-hashes.csv -NoTypeInformation   #
after the STIG Viewer updates
```

> **WHAT SUCCESS LOOKS LIKE** The manifest hash matched and no baseline file changed, both rescans used the SCC version, benchmark release and profile in handoff.txt, each controller's changes are listed and attributed, the checklist copies carry the new results and re-checked answers while the baseline copies keep their hashes, and every findings-record item has a resolution.

Your record

Evidence to keep: Keep both rescan sessions with their hash lists, the two change lists, the updated checklist copies with their hashes, and the findings record with a resolution and evidence for every item, all in C:\Evidence\hardened.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why keep the same benchmark and SCC versions for the rescan?

> **REMEMBER** Same versions, honest comparison. Copies of the checklists carry the new results; the baseline stays sealed. Open items end the lesson classified, never mysterious.

Microsoft · Gpresult

DISA · SCAP content and the SCAP Compliance Checker (SCC)

DISA · SRG/STIG tools (STIG Viewer)

NIST · National Checklist Program (SP 800-70)

LESSON 05 / ABOUT 25 MIN

Set the rescan cadence and exception record

> **WHY THIS MATTERS** Hardening is a state you maintain, not a step you finish. Close the course with an owned exception record and a backed-up policy state, and decide who rescans, when, and which event forces an early look.

In this lesson you will

- Consolidate deviations into an owned, dated exception record.
- Define the quarterly and event-driven rescan cadence.
- Export and back up the applied policy state as evidence.

Follow the build

1. Consolidate the deviations from lesson 3 and the items lesson 4 resolved as deviations into one exception record, C:\Evidence\exception-record.csv — rule, setting, reason, compensating measure, risk note, owner and review date — and file a dated copy in C:\Evidence\hardened. Course 1.4's example belongs here — the rule expecting the PDC emulator to synchronize with an authorized external time source, which the course 1.3 design answers with a declared, checked clock. It stays a living record outside the sealed folder: later courses add their entries to it, and it travels into the authorization path as part of the Body of Evidence.
2. Set the standing cadence: review each quarterly DISA release for applicable updates, and rescan after any role addition or significant configuration change — course 1.6's closing rescan of both controllers, once its certificates and autoenrollment policy reach them, is the first change-driven run. When you adopt a new release, scan once with the new content before changing any policy, so the record separates what the content changed from what your policies changed.
3. Back up every GPO, export the Group Policy reports, and export each link beside the backup: restoring a GPO from backup brings back its settings and permissions, not its links. Together they make the applied policy state recoverable and reviewable without a live console.
4. Write the handoff a future administrator or assessor would need — where the evidence lives, which versions produced it, and what is intentionally open — and hash C:\Evidence\hardened into C:\Evidence\hardened-manifest.csv. Course 1.8 later moves SCC and STIG Viewer to AdminJumpBox01 and links these policies to the admin seats' OUs; until then the cadence runs at the controllers' consoles.

Check your result

```
# Seed the exception record from the findings resolved as deviations; add lesson 3's
deviations and fill in every column
Import-Csv C:\Evidence\hardened\findings\findings-record.csv | Where-Object Resolution -eq
'deviation' | Select-Object Target, GroupId, StigId, Title, Setting, Reason,
CompensatingMeasure, RiskNote, Owner, ReviewDate | Export-Csv C:\Evidence\exception-
record.csv -NoTypeInformation -NoClobber
Copy-Item C:\Evidence\exception-record.csv "C:\Evidence\hardened\exception-record-$(Get-
Date -Format yyyy-MM-dd).csv"   # once it is complete
New-Item -ItemType Directory C:\Evidence\hardened\gpo-backup -Force | Out-Null
Backup-GPO -All -Path C:\Evidence\hardened\gpo-backup -Comment 'Course 1.5 closing state'
Get-GPOReport -All -ReportType Html -Path C:\Evidence\hardened\gpo-report.html
'DC=sbd,DC=test', 'OU=Domain Controllers,DC=sbd,DC=test',
'OU=Servers,OU=SBD,DC=sbd,DC=test' | ForEach-Object { (Get-GPInheritance -Target
```

```
$_).GpoLinks } | Select-Object Target, Order, DisplayName, Enabled, Enforced | Export-Csv
C:\Evidence\hardened\gpo-links.csv -NoTypeInformation
Get-ChildItem C:\Evidence\hardened -Recurse -File | Get-FileHash -Algorithm SHA256 |
Export-Csv C:\Evidence\hardened-manifest.csv -NoTypeInformation
Get-FileHash -Algorithm SHA256 C:\Evidence\hardened-manifest.csv
```

WHAT SUCCESS LOOKS LIKE The exception record has owners, compensating measures and review dates, with a dated copy filed, the GPO set is backed up with its links and reports beside it, the evidence folder is sealed in the manifest with its own hash recorded, and the rescan triggers are written where course 1.6 will meet them.

Your record

Evidence to keep: Finish the hardening checklist: the living exception record in C:\Evidence and its dated copy, the GPO backup with its link export and report, C:\Evidence\hardened-manifest.csv with its own hash, the cadence, and the named owner of the next review.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What triggers a rescan before the next quarterly cycle?

REMEMBER Exceptions have owners and review dates. Rescans follow the DISA quarter and every meaningful change. The applied GPO state is exported, backed up, and hashed.

Microsoft · Back up, restore, migrate, and copy Group Policy Objects

Microsoft · Backup-GPO

DISA · STIG Group Policy Objects package

NIST · National Checklist Program (SP 800-70)

© 2026 Secure By Design Team LLC.

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design and build the OU structure	☐ yes	
02 Learn how Group Policy applies	☐ yes	
03 Import and link the DISA GPOs	☐ yes	
04 Rescan, reconcile, and record	☐ yes	
05 Set the rescan cadence and exception record	☐ yes	

Open items carried forward

Next in the learning path

That completes Harden with Group Policy. Course 1.6 builds the two-tier PKI on this hardened base: its domain-joined servers join the Servers OU, where the member-server policies already apply, and its closing rescan of the controllers is this cadence's first change-driven run.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.